Vulnerability Assessment Report for OWASP Juice shop

Disclaimer

A vulnerability assessment represents the security posture of the system at a specific point in time. The identified vulnerabilities and recommendations are based solely on the information and access available during the assessment period, and do not account for any changes made before or after the evaluation.

Due to the time-bound nature and defined scope of the assessment, it may not cover all possible vulnerabilities or security controls within the system. The assessment primarily focuses on identifying known and detectable weaknesses that could be exploited by potential attackers.

It is recommended to perform regular vulnerability assessments, along with continuous monitoring and remediation efforts, to maintain and improve the overall security posture of the system.

Assessment Overview

From March 19, 2026, to April 19, 2026, Future Interns engaged me to evaluate the security posture of a permitted, intentionally vulnerable website against current industry best practices, including an external vulnerability assessment. All testing performed was based on the tools mentioned in the task details (Nmap, OWASP ZAP, and web development tools).

Assessment Components

External Vulnerability Assessment :-

An external vulnerability assessment evaluates the security posture of a system from an outside perspective, without using internal resources or privileged access. The objective is to identify known vulnerabilities and misconfigurations that could be exploited by attackers. During the assessment, I gathered publicly available information through open-source intelligence (OSINT), including exposed data and potential entry points, and performed scanning and enumeration using tools such as Nmap and OWASP ZAP to detect weaknesses in external systems.

Severity Ratings

High – 7.0 -10.0 :-

Exploiting these vulnerabilities may be more challenging, but if successful, it could lead to privilege escalation, data breaches, or system downtime. It is recommended to develop a remediation plan and address these issues promptly.

Moderate – 4.0 – 6.9 :-

Some vulnerabilities are present but are not directly exploitable or would require additional steps, such as social engineering, to be leveraged. It is recommended to plan remediation for these issues after addressing higher-priority vulnerabilities.

Low - 0.0 – 3.9 :-

These vulnerabilities cannot be exploited directly, but addressing them would help reduce the organization's overall attack surface. It is recommended to plan remediation and apply fixes during the next scheduled maintenance window.

Executive Summary

From March 19, 2026, to April 19, 2026, as part of an internship provided by Future Interns, a sample vulnerability assessment was conducted on the OWASP Juice Shop website. The tools used for scanning included Nmap, OWASP ZAP, and web development tools (such as browser inspection tools). The assessment focused on identifying known vulnerabilities and misconfigurations, and validating them through analysis to determine their impact.

Through this process, several vulnerabilities of varying severity were identified, which could potentially expose sensitive data and weaken the overall security posture of the application. These vulnerabilities were discovered using basic reconnaissance and standard testing techniques, indicating a higher risk if left unaddressed.

It is strongly recommended that these vulnerabilities be remediated promptly to improve the security of the application. Below is a brief report of the vulnerability assessment findings.

Total vulnerabilities found	High Severity	Medium Severity	Low Severity
8	2	6	0

Assessment Summary

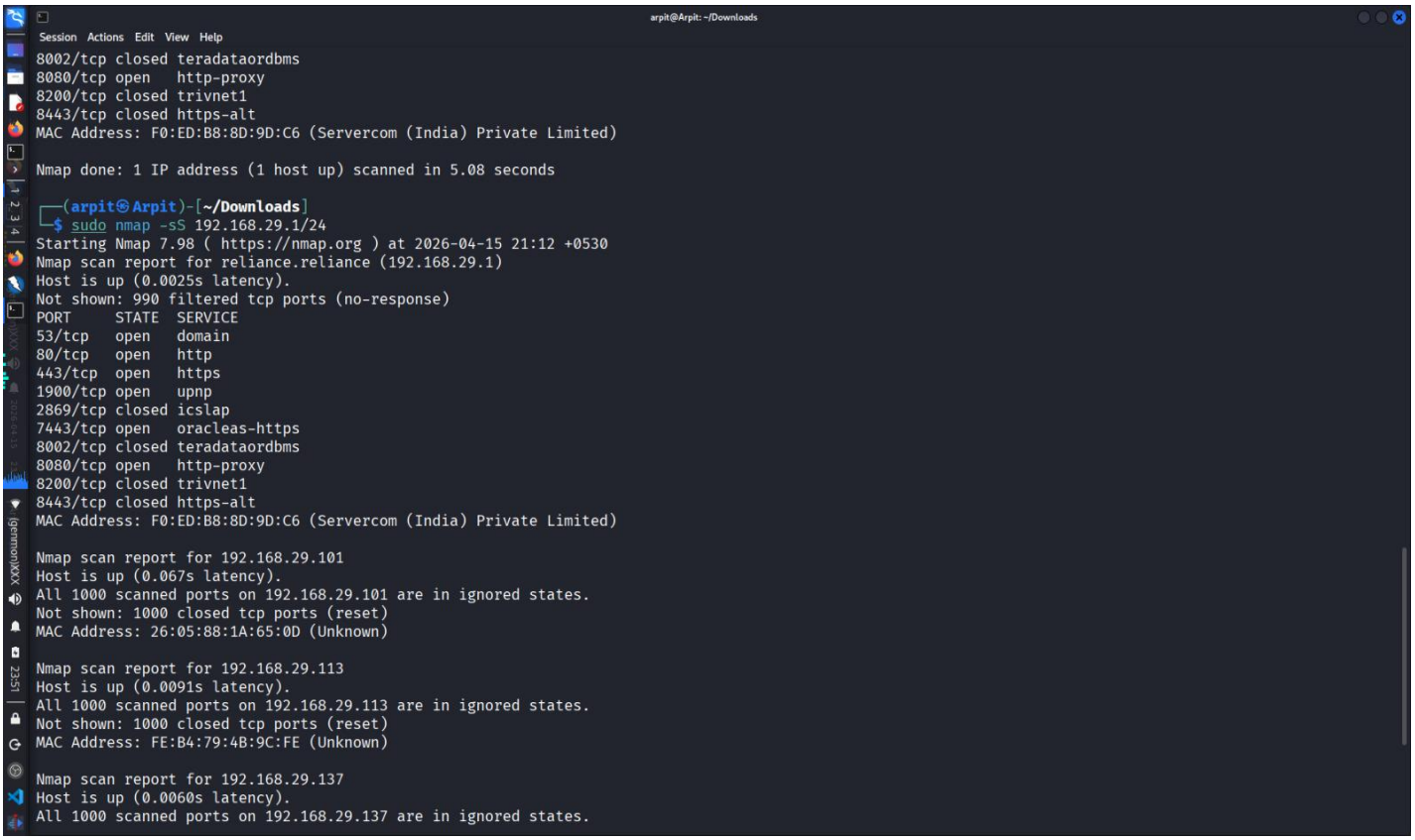
Sl. no	Vulnerability	Description	Severity
1	UPnP Exposure (Port 1900)	UPnP is insecure because it can enable unauthorized port forwarding and expose the internal network.	High
2	SQL injection	SQL injection is a vulnerability where attackers insert malicious SQL code into input fields to access or manipulate a database.	High
3	Multiple Web Interfaces (80, 443, 7443, 8080)	Having multiple web ports open increases the attack surface, making it easier for attackers to exploit issues like default credentials, web interface vulnerabilities (XSS, CSRF), or authentication bypass.	Medium
4	CSP: Failure to Define Directive with No Fallback	The Content Security Policy is misconfigured because critical directives like frame-ancestors and form-action are missing and have no fallback, effectively allowing unrestricted behavior.	Medium
5	Content Security Policy (CSP) Header Not Set	Content Security Policy (CSP) is a security feature that helps prevent attacks like XSS and data injection by restricting which sources of content a browser can load.	Medium
6	Cross-Domain Misconfiguration	A CORS misconfiguration allows unauthorized cross-domain requests, potentially exposing sensitive data from unauthenticated endpoints to third-party domains.	Medium
7	Missing Anti-clickjacking Header	The response lacks protection against clickjacking because it does not include headers like Content-Security-Policy (frame-ancestors) or X-Frame-Options.	Medium
8	Session ID in URL Rewrite	Using URL rewriting for session IDs can expose them through referrer headers, browser history, or server logs, increasing the risk of session hijacking.	Medium

Vulnerability Assessment test findings

1.UPnP Exposure (Port 1900) (High)

Description	UPnP (Universal Plug and Play) allows devices on a network to automatically open ports on the router without authentication, which makes it convenient but insecure. Malicious software on a device can exploit this to create unauthorized port forwarding rules, exposing internal services to the internet. This increases the risk of attackers accessing sensitive systems, leading to data breaches, device compromise, or full network intrusion.
Impact	High

Proof of concept:



```
arpit@Arpit: ~/Downloads
Session  Actions  Edit  View  Help
8002/tcp closed teradataordbms
8080/tcp open   http-proxy
8200/tcp closed trivnet1
8443/tcp closed https-alt
MAC Address: F0:ED:B8:8D:9D:C6 (Servercom (India) Private Limited)

Nmap done: 1 IP address (1 host up) scanned in 5.08 seconds

┌──(arpit㉿Arpit)-[~/Downloads]
└─$ sudo nmap -sS 192.168.29.1/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-15 21:12 +0530
Nmap scan report for reliance.reliance (192.168.29.1)
Host is up (0.0025s latency).
Not shown: 990 filtered tcp ports (no-response)
PORT     STATE  SERVICE
53/tcp   open   domain
80/tcp   open   http
443/tcp  open   https
1900/tcp open   upnp
2869/tcp closed icslap
7443/tcp open   oracleas-https
8002/tcp closed teradataordbms
8080/tcp open   http-proxy
8200/tcp closed trivnet1
8443/tcp closed https-alt
MAC Address: F0:ED:B8:8D:9D:C6 (Servercom (India) Private Limited)

Nmap scan report for 192.168.29.101
Host is up (0.067s latency).
All 1000 scanned ports on 192.168.29.101 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 26:05:88:1A:65:0D (Unknown)

Nmap scan report for 192.168.29.113
Host is up (0.0091s latency).
All 1000 scanned ports on 192.168.29.113 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: FE:B4:79:4B:9C:FE (Unknown)

Nmap scan report for 192.168.29.137
Host is up (0.0060s latency).
All 1000 scanned ports on 192.168.29.137 are in ignored states.
```

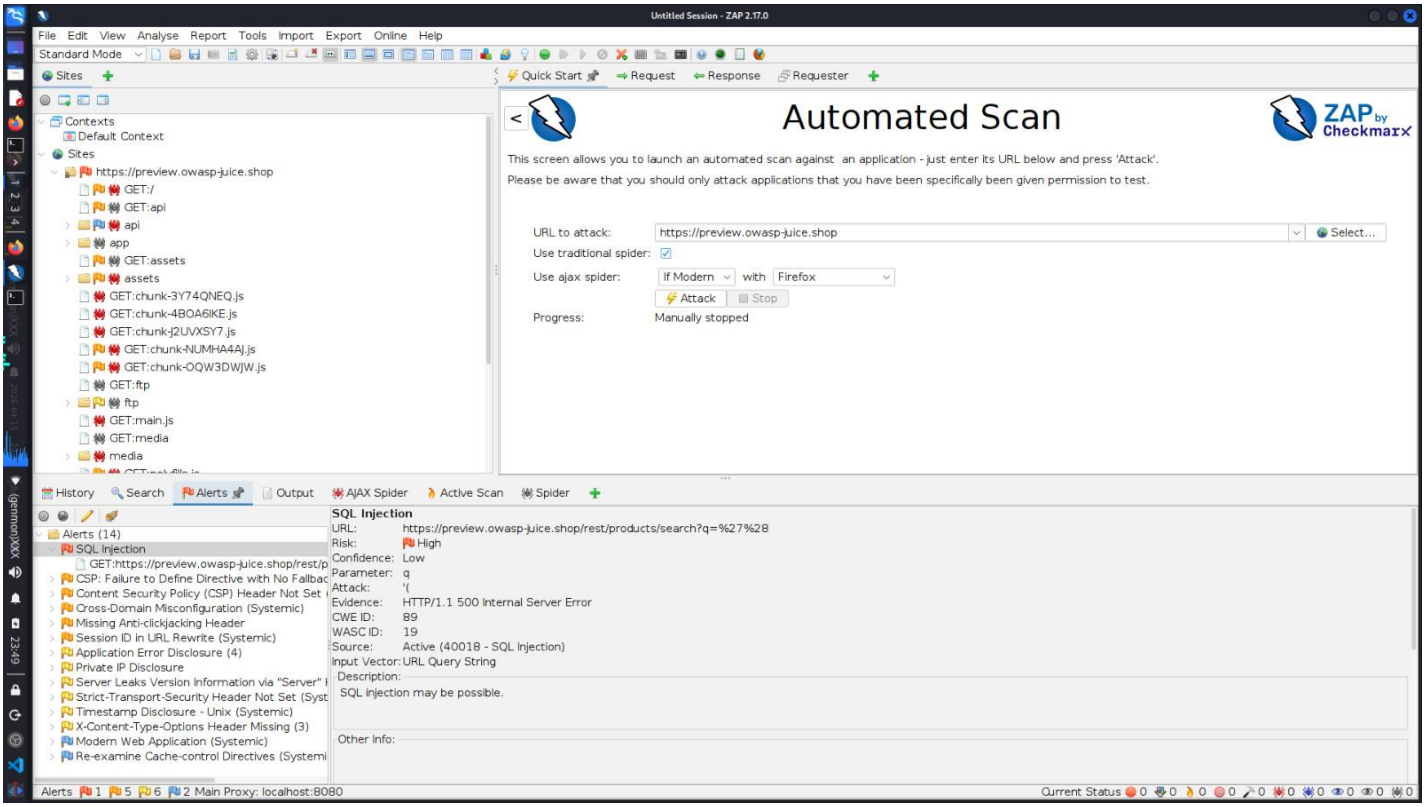
Recommendation:-

Disable UPnP on the router unless it is absolutely required, and instead use manual port forwarding with strict control over which ports are opened. Regularly monitor and audit open ports, update router firmware, and ensure all devices on the network are secure and free from malware. Additionally, restrict access to the router's admin panel with strong credentials and avoid exposing management interfaces to the internet.

2.SQL injection (High)

Description	SQL injection occurs when an application includes unsanitized user input in database queries, allowing attackers to insert malicious SQL code. This can alter how the query is executed, enabling attackers to bypass login systems, retrieve sensitive data, or modify and delete database records.
Impact	High

Proof of concept:



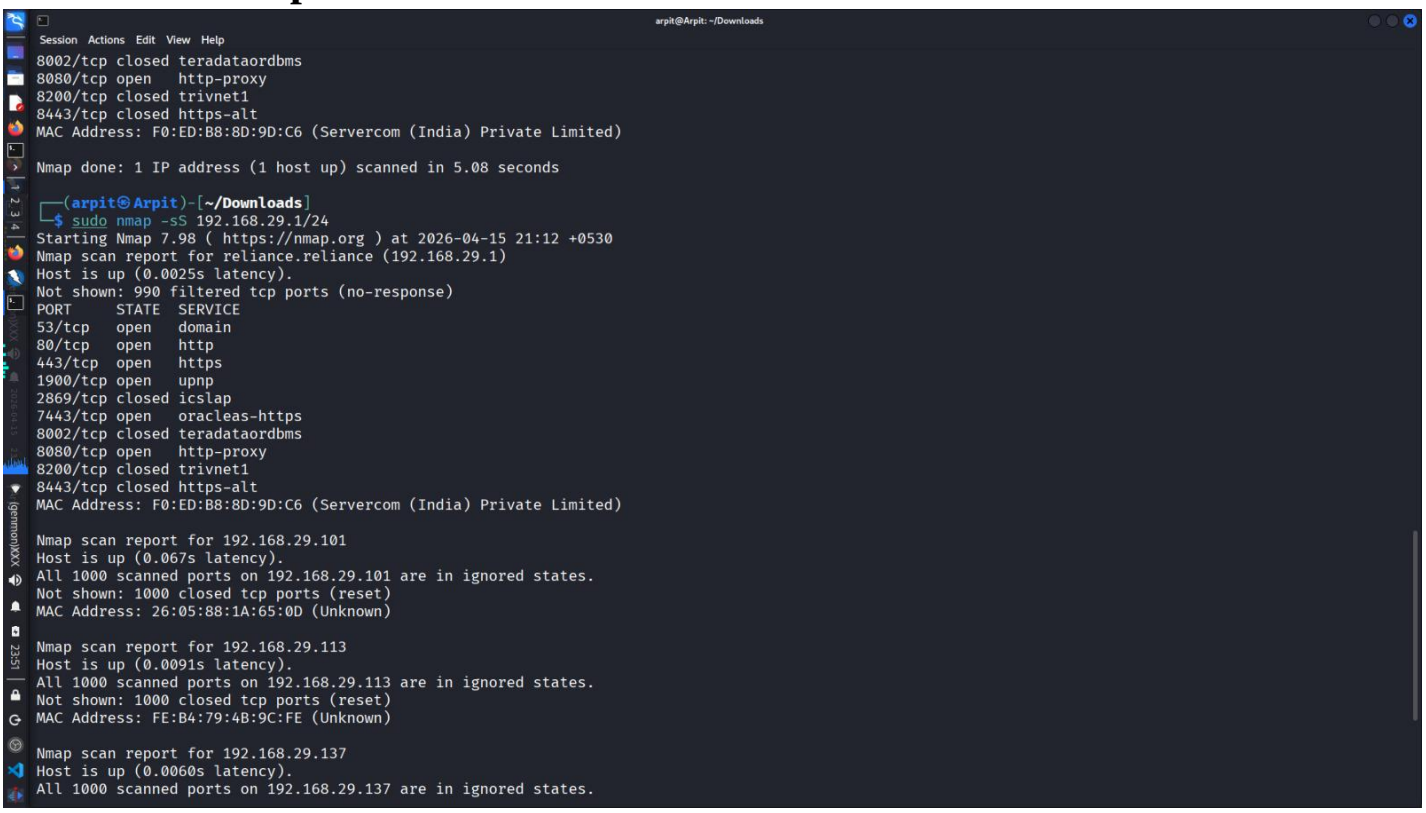
Recommendation:-

Prevent SQL injection by using parameterized queries (prepared statements) so user input is never executed as SQL code. Validate and sanitize all inputs, avoid dynamic query building, and use ORM frameworks where possible. Limit database permissions (least privilege), disable detailed error messages, and regularly test the application using tools like OWASP ZAP.

3.Multiple Web Interfaces (80, 443, 7443, 8080) (Medium)

Description	When multiple web ports are open, each port exposes a service that can be targeted by attackers, increasing the overall attack surface. Attackers can scan these ports to find weak points such as default credentials, misconfigurations, or vulnerabilities like XSS, CSRF, and authentication bypass, making it easier to gain unauthorized access.
Impact	Medium

Proof of concept:



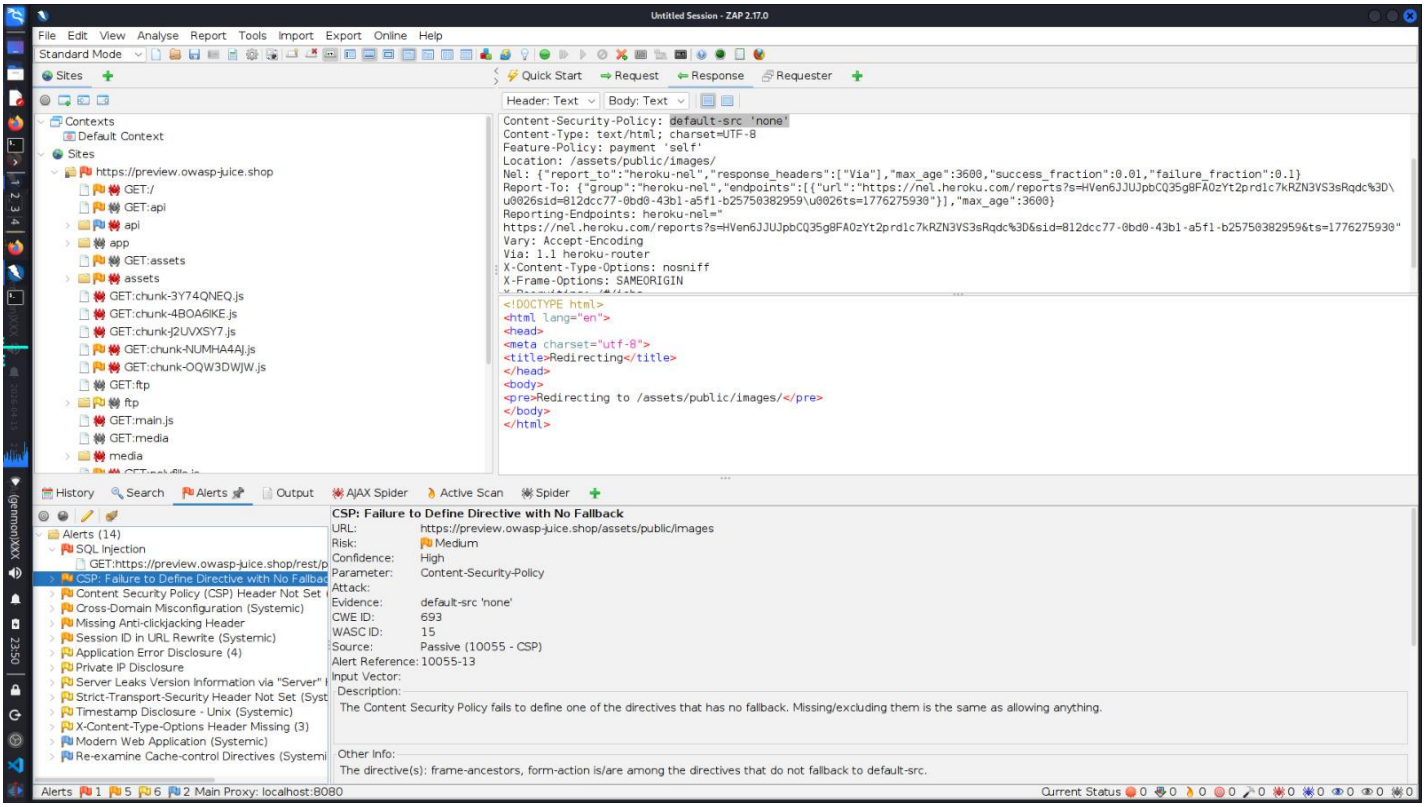
Recommendation:-

Minimize the attack surface by closing all unnecessary ports and disabling unused services. Restrict access to required ports using firewalls or security groups, and ensure only trusted IPs can reach sensitive services. Change default credentials, keep all services updated, and regularly scan for open ports using tools like Nmap to identify and remediate exposures

4. CSP: Failure to Define Directive with No Fallback (Medium)

Description	Content Security Policy (CSP) controls what content a browser can load, but if directives like frame-ancestors and form-action are missing, there are no restrictions on framing or form submissions. This can lead to risks like clickjacking and data leakage, as these directives do not fall back to default-src, allowing unrestricted behavior.
Impact	Medium

Proof of concept:



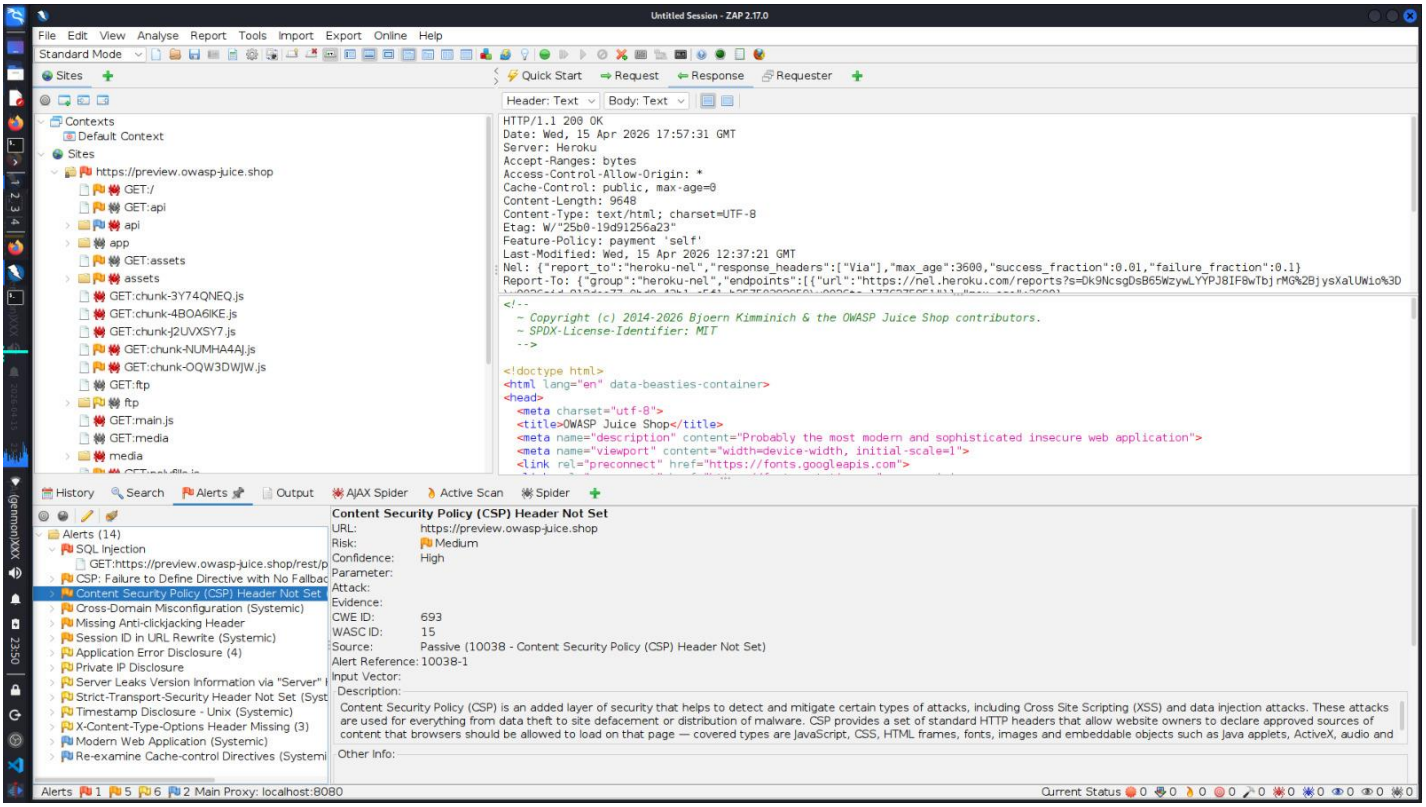
Recommendation:-

Define a strict Content Security Policy by explicitly adding directives like frame-ancestors and form-action to control framing and form submissions. Restrict these to trusted domains only, avoid using wildcards, and regularly review and test the CSP configuration to ensure it effectively mitigates risks like clickjacking and data leakage.

5.Content Security Policy (CSP) Header Not Set (Medium)

Description	Content Security Policy (CSP) is implemented through HTTP headers to control which content sources a browser can load. By allowing only trusted sources, it helps prevent attacks like XSS and data injection by blocking unauthorized scripts and resources from executing.
Impact	Medium

Proof of concept:



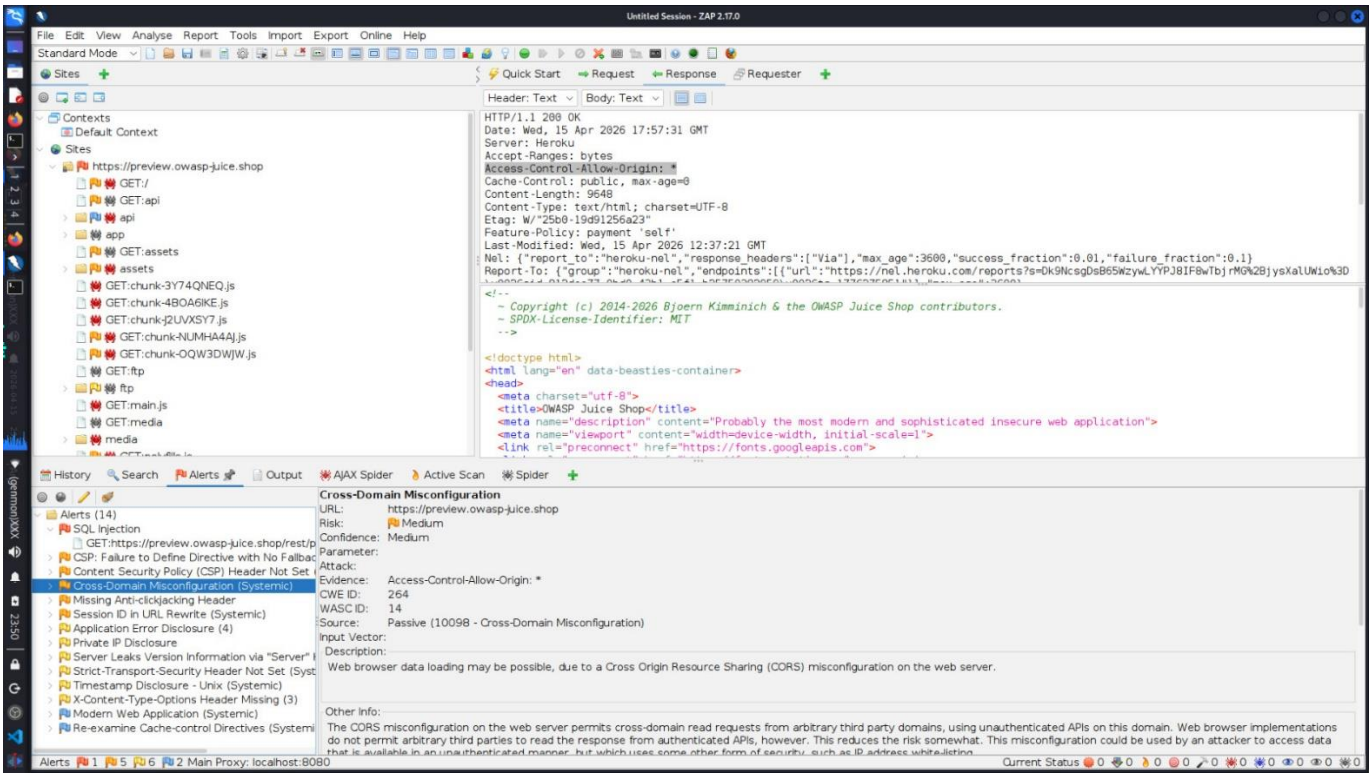
Recommendation:-

Implement a strong Content Security Policy by defining strict rules for allowed content sources (e.g., only trusted domains). Avoid using wildcards, minimize inline scripts, and use hashes where required. Regularly test and refine the CSP to ensure it effectively blocks unauthorized content and reduces the risk of XSS and data injection attacks.

6. Cross-Domain Misconfiguration (Medium)

Description	CORS controls which domains can access a server's resources, but if misconfigured (e.g., allowing all origins), it lets malicious websites send requests and read responses. This can expose sensitive data from unauthenticated endpoints and weaken browser security protections.
Impact	Medium

Proof of concept:



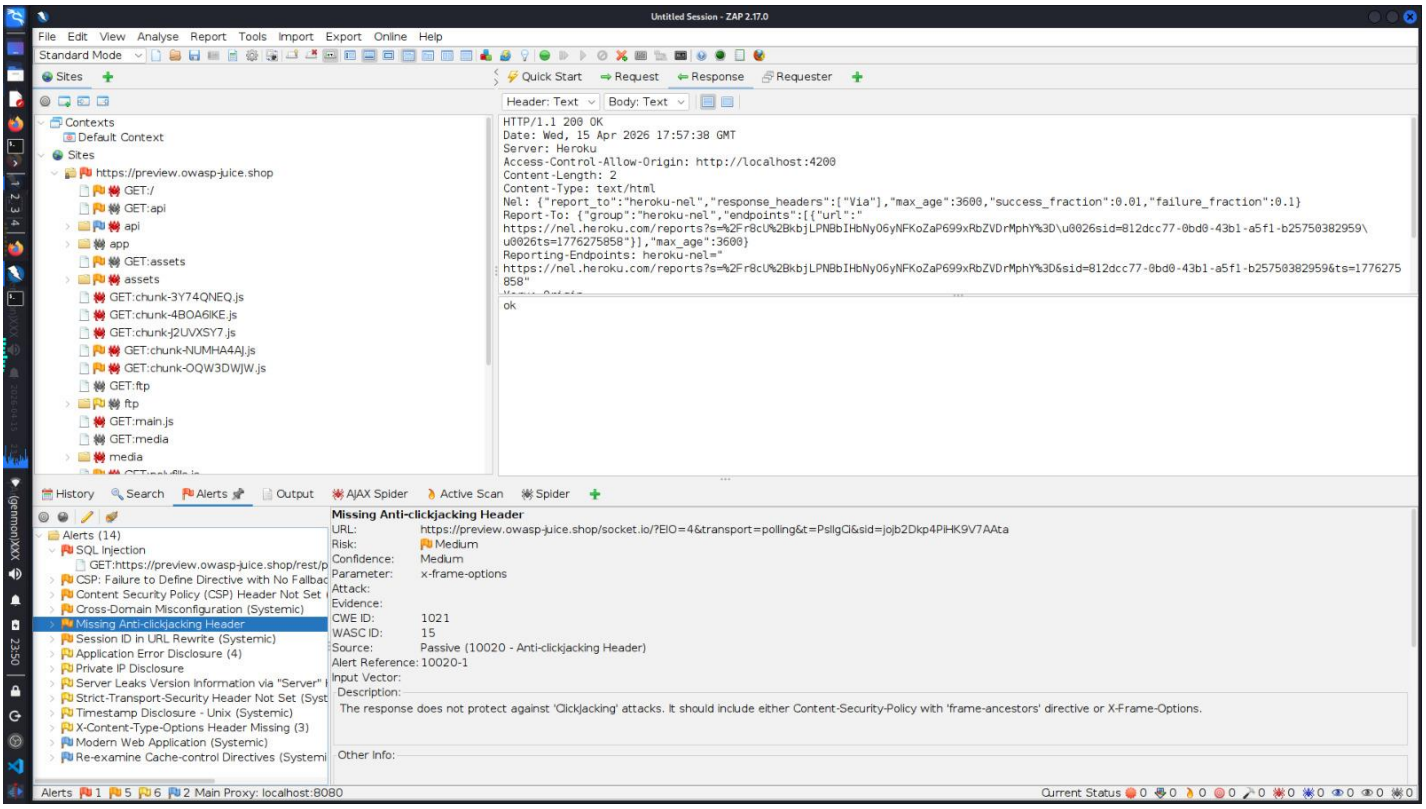
Recommendation:-

Configure CORS to allow only trusted domains instead of using wildcards (*). Validate and whitelist specific origins, restrict allowed HTTP methods and headers, and avoid exposing sensitive data through unauthenticated endpoints. Additionally, implement proper authentication and regularly review CORS settings to ensure they are secure.

7.Missing Anti-clickjacking Header(Medium)

Description	Clickjacking occurs when a website can be embedded in a malicious page using iframes, tricking users into clicking hidden elements. Without headers like X-Frame-Options or CSP frame-ancestors, the site has no protection against such attacks, increasing the risk of unauthorized actions.
Impact	Medium

Proof of concept:



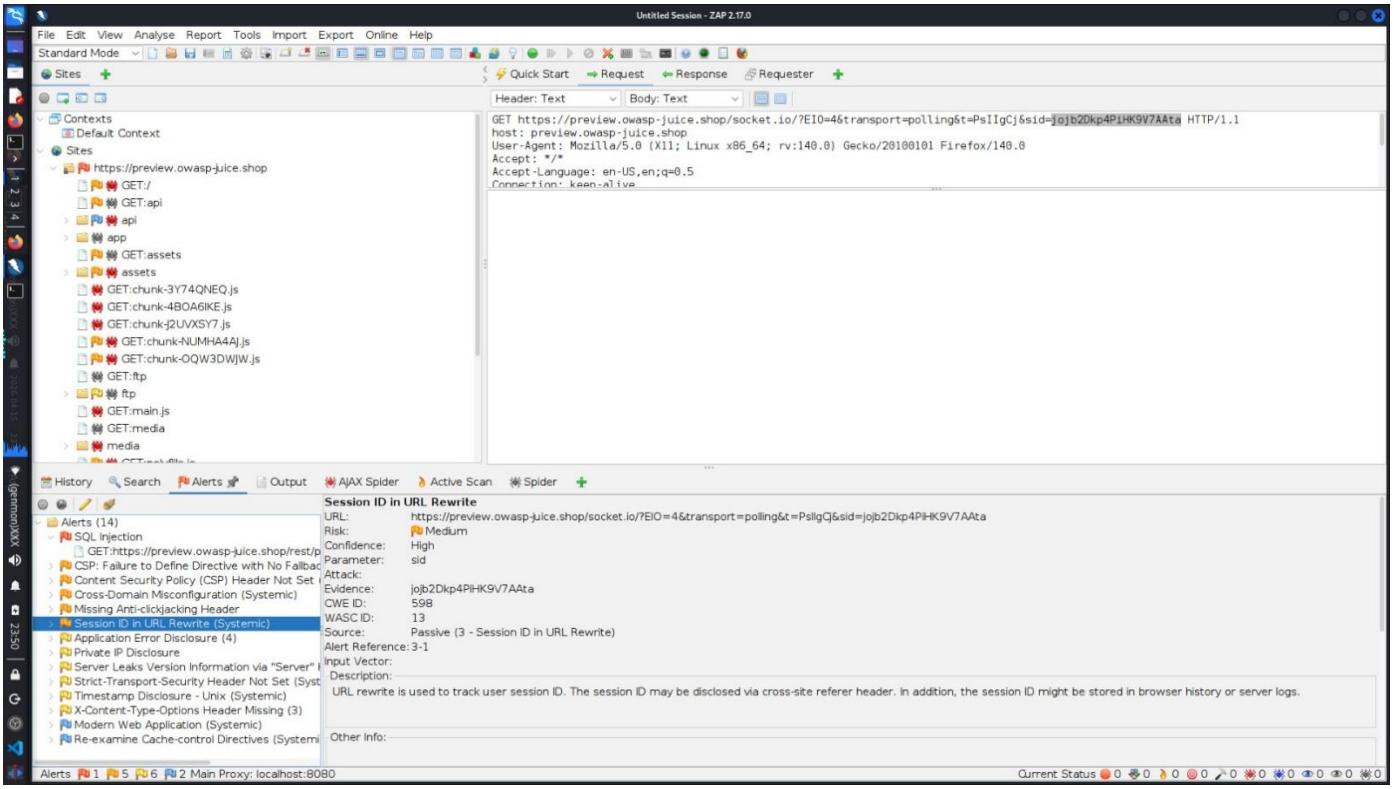
Recommendation:-

Prevent clickjacking by implementing security headers such as X-Frame-Options (set to DENY or SAMEORIGIN) and/or a Content Security Policy with the frame-ancestors directive to restrict which domains can embed the site. Regularly test these configurations to ensure the application cannot be framed by unauthorized sources.

8.Session ID in URL Rewrite (Medium)

Description	When session IDs are included in URLs, they can be exposed through referrer headers, browser history, and server logs. If an attacker obtains this session ID, they can hijack the user's session and gain unauthorized access.
Impact	Medium

Proof of concept:



Recommendation:-

Avoid using URL rewriting for session management and store session IDs securely in cookies instead. Configure cookies with security flags such as HttpOnly, Secure, and SameSite to prevent unauthorized access. Additionally, implement session timeouts, regenerate session IDs after login, and avoid logging sensitive session information in URLs